

Cyber Threat Intelligence

Executive Briefing

Report Date: July 11, 2026

Generated: 2026-07-11 19:41 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
1	3	6	0	20

2. Executive Summary

As of July 11, 2026, the security operations center has concluded an analysis of 20 identified vulnerabilities, categorized as 1 Critical, 3 High, 6 Medium, and 0 Low severity findings. This current threat landscape reflects a High organizational risk posture, characterized by vulnerabilities that could facilitate unauthorized system access and remote code execution if left unmitigated. The primary threat is identified as CVE-2026-52778, Remote Code Execution in YesWiki Formula Calculator, which mandates immediate prioritization due to the potential for full system compromise via arbitrary command execution. The enterprise must adopt an aggressive defensive posture, prioritizing the immediate patching or compensatory control implementation for all high-impact vulnerabilities. We recommend an urgent response strategy focused on containment and systematic remediation to ensure operational continuity and data integrity.

3. Critical Action List

- Immediately isolate or patch the YesWiki Formula Calculator to mitigate CVE-2026-52778, as it represents the highest risk of remote code execution, with remediation required within 24 hours.
- Perform an urgent security configuration review and implement input sanitization controls for the ReactionManager component to neutralize CVE-2026-52775 within 48 hours.
- Conduct an immediate audit and apply necessary security patches to the Page Delete API to remediate the second-order SQL injection vulnerability identified as CVE-2026-52771 within 72 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-52778	Remote Code Execution in YesWiki ...	9.8	Critical	88/100	CWE-94
CVE-2026-52766	Unauthorized Page Deletion in Yes...	9.1	Unknown	82/100	CWE-276
CVE-2026-52777	PHP Object Injection in YesWiki B...	8.8	Unknown	79/100	CWE-352

CVE-2026-52775	SQL Injection in YesWiki Reaction...	8.8	High	79/100	CWE-89
CVE-2026-52771	Second-Order SQL Injection in Yes...	8.3	High	75/100	CWE-89
CVE-2026-52769	Server-Side Request Forgery in Ye...	8.3	Unknown	75/100	CWE-918
CVE-2026-52767	Signature Verification Bypass in ...	8.2	Unknown	74/100	CWE-347
CVE-2026-53932	OS Command Injection in laravel-b...	8.0	Unknown	72/100	CWE-77
CVE-2026-52770	SQL Injection in YesWiki Bazar Li...	7.5	High	68/100	CWE-89
CVE-2026-53727	SSRF and Local File Disclosure in...	7.5	Unknown	68/100	CWE-918
CVE-2026-52762	Server-Side Template Injection in...	7.2	Unknown	65/100	CWE-1336
CVE-2026-53637	Order Modification Vulnerability ...	6.5	Medium	59/100	CWE-672
CVE-2026-52763	SQL Injection in YesWiki Recent C...	6.5	Medium	59/100	CWE-89
CVE-2026-53769	Upload Policy Bypass in Avo Compo...	6.5	Medium	59/100	CWE-862
CVE-2026-52774	Reflected XSS in YesWiki Bazar Wi...	6.1	Medium	55/100	CWE-80
CVE-2026-52773	Reflected XSS in YesWiki Revision...	6.1	Medium	55/100	CWE-80
CVE-2026-52772	Stored XSS in YesWiki Bazar Templ...	5.5	Unknown	50/100	CWE-79
CVE-2026-53602	Host Revocation Bypass in Nebula ...	9.1	Unknown	49/100	CWE-613
CVE-2026-53760	Cross-Site Request Forgery in Adm...	5.2	Unknown	47/100	CWE-352
CVE-2026-53638	Payment Method Restriction Bypass...	4.3	Medium	39/100	CWE-863

5. Detailed Vulnerability Findings

CVE-2026-52778

Finding: Remote Code Execution in YesWiki Formula Calculator

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-94

Score Provenance: Unverified

MITRE ATT&CK: T1190, T1059.008

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

YesWiki utilizes an unsafe eval() call within its Formula Calculator feature, introducing a critical remote code execution vulnerability. This issue is caused by a failure to sanitize or restrict mathematical expressions before passing them directly into the PHP eval() interpreter. An unauthenticated remote attacker can exploit this flaw to execute arbitrary system commands on the hosting server, potentially compromising the host completely.

Proof of Concept (PoC):

An unauthenticated remote attacker targets the YesWiki Formula Calculator endpoint. The attacker sends a POST request to /action/formula with a payload containing system commands enclosed in an eval-executable formula syntax.

The server receives the request and directly evaluates the user-supplied math expression using the unsafe PHP eval() function. This results in arbitrary remote code execution, granting the attacker a shell with the privileges of the web daemon.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52778>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52778>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52778>

CVE-2026-52766

Finding: Unauthorized Page Deletion in YesWiki Comments

CVSS v3.1 Score: 9.1 | Severity: Unknown | Urgency Score: 82/100 | CWE: CWE-276

Score Provenance: Unverified

MITRE ATT&CK: T1548, T1070

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

YesWiki is vulnerable to unauthenticated arbitrary page deletion via the erasespamedcomments action handler. The technical root cause is a failure to enforce authorization and privilege checks on the erasespamedcomments routine. An unauthenticated attacker can exploit this weakness remotely to wipe pages from the system, resulting in severe data loss and availability impact.

Proof of Concept (PoC):

An unauthenticated remote attacker targets a YesWiki site containing the spam comment clean-up utility. The attacker sends a POST request to /action/erasespamedcomments with parameters referencing a target legitimate page identifier. The application executes the deletion module without validating whether the requesting user possesses administrator privileges. This results in immediate and permanent deletion of pages from the public wiki instance, destroying user content and application data.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52766>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52766>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52766>

CVE-2026-52777

Finding: PHP Object Injection in YesWiki BazarImportAction

CVSS v3.1 Score: 8.8 | Severity: Unknown | Urgency Score: 79/100 | CWE: CWE-352

Score Provenance: Unverified

MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low

Attack Complexity	Low
User Interaction	None

Scope	Unchanged
Integrity Impact	High

Confidentiality Impact	High
Availability Impact	High

Description:

YesWiki is vulnerable to an authenticated PHP Object Injection vulnerability in the BazarImportAction class via the unserialize function. The root cause is the unsafe deserialization of untrusted user input within the Bazar import mechanism without adequate validation or class whitelisting. A remote attacker can exploit this vulnerability to initiate arbitrary object instantiation, leading to denial of service or remote code execution.

Proof of Concept (PoC):

An unauthenticated attacker crafts a malicious webpage that leverages Cross-Site Request Forgery to target an authenticated YesWiki administrator. The webpage triggers a POST request to /bazar/import targeting the BazarImportAction component, embedding a serialized PHP object payload. The server processes the request on behalf of the admin session, passing the payload directly to PHP's unserialize() function. This results in arbitrary PHP Object Injection and remote command execution under the privileges of the running web application server.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52777>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52777>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52777>

CVE-2026-52775

Finding: SQL Injection in YesWiki ReactionManager

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-89

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190, T1505

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

YesWiki contains an authenticated SQL injection vulnerability within its ReactionManager component. This flaw exists because user input processed by ReactionManager is directly concatenated into SQL queries without proper sanitization or parameter binding. An authenticated attacker can exploit this vulnerability to execute arbitrary SQL queries, leading to unauthorized database read, write, and deletion privileges.

Proof of Concept (PoC):

An authenticated remote attacker targets the YesWiki platform's ReactionManager interface. The attacker sends a POST request to /action/reaction_manager containing SQL syntax payload within the reaction_id parameter. The database abstraction layer processes the unsanitized parameter and executes the raw SQL query on the backend database. This results in full extraction of sensitive database content, including administrative password hashes.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52775>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52775>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52775>

CVE-2026-52771

Finding: Second-Order SQL Injection in YesWiki Delete API

CVSS v3.1 Score: 8.3 | Severity: High | Urgency Score: 75/100 | CWE: CWE-89

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

YesWiki is vulnerable to a second-order SQL injection within its Page Delete API endpoint. This issue is rooted in the ApiController::deletePage method, which utilizes unescaped page tag values previously stored in the database. An authenticated attacker can exploit this to execute secondary database queries, compromising the confidentiality and integrity of backend data stores.

Proof of Concept (PoC):

An authenticated remote user inserts a malicious SQL payload into a page title or page tag during normal page creation. The attacker then sends a DELETE request to /api/pages/delete targeting the recently created page tag. The ApiController::deletePage function retrieves the stored malicious tag and dynamically appends it to a delete query without parameterization. This results in execution of secondary commands, leading to truncation of database tables or unauthorized privilege modification.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52771>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52771>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52771>

CVE-2026-52769

Finding: Server-Side Request Forgery in YesWiki ActivityPub

CVSS v3.1 Score: 8.3 | Severity: Unknown | Urgency Score: 75/100 | CWE: CWE-918

Score Provenance: Unverified

MITRE ATT&CK: T1190, T1018

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:L/A:L

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	Low

Description:

YesWiki contains an unauthenticated Server-Side Request Forgery vulnerability within its ActivityPub integration. The vulnerability arises because the server parses and fetches external URIs specified in the Signature.keyId parameter without restricting target hosts. An unauthenticated remote attacker can exploit this to force the YesWiki host to query internal services or map internal network infrastructure.

Proof of Concept (PoC):

An unauthenticated remote attacker targets the ActivityPub inbox endpoint of YesWiki. The attacker transmits a payload containing a Signature header with a keyId value pointing to a localhost administrative service. The application attempts to retrieve the public key by executing an outbound HTTP GET request to the internal loopback URL. This results in SSRF, enabling the attacker to interact with backend network services shielded by typical perimeter firewalls.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52769>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52769>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52769>

CVE-2026-52767

Finding: Signature Verification Bypass in YesWiki ActivityPub

CVSS v3.1 Score: 8.2 | Severity: Unknown | Urgency Score: 74/100 | CWE: CWE-347

Score Provenance: Unverified
MITRE ATT&CK: T1556, T1116

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

YesWiki is vulnerable to an unauthenticated ActivityPub Signature-Verification Bypass due to insecure cryptographic checking. The application improperly handles the openssl_verify return value, treating an error integer code of -1 as a valid signature confirmation. A remote attacker can exploit this security flaw to forge ActivityPub payloads and bypass federation controls, leading to spoofed content injection.

Proof of Concept (PoC):

An unauthenticated remote attacker crafts an ActivityPub message with an invalid key structure. The attacker sends the message containing an explicitly deformed public key signature structure to the /activitypub/inbox endpoint. The backend processes the signature via openssl_verify which encounters an error and returns -1, which is loosely evaluated as a truthy status. This results in complete cryptographic validation bypass, granting the attacker the capability to spoof identities across federated channels.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52767>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52767>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52767>

CVE-2026-53932

Finding: OS Command Injection in laravel-backup-restore

CVSS v3.1 Score: 8.0 | Severity: Unknown | Urgency Score: 72/100 | CWE: CWE-77

Score Provenance: Unverified
MITRE ATT&CK: T1059, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

The laravel-backup-restore package is vulnerable to OS Command Injection during database restoration processes. This occurs due to unescaped shell concatenation of user-supplied database names or configuration parameters when invoking command-line utilities. An attacker can exploit this vulnerability to achieve remote system shell access, posing a severe threat to server integrity.

Proof of Concept (PoC):

An authenticated developer or manager targets the database restore function in the laravel-backup-restore administrative dashboard. The attacker triggers a restore process using a backup filename manipulated with shell operators, such as 'restore; rm -rf / ;.gz'. The backend invokes shell_exec to execute the native mysql recovery tool without sanitizing the database file path variable. This results in the execution of the injected shell instructions, leading to complete server deletion or malicious tool deployment.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53932>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53932>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53932>

CVE-2026-52770

Finding: SQL Injection in YesWiki Bazar Listing APIs

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-89

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190, T1114

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

YesWiki suffers from a SQL injection vulnerability in its public Bazar entry-listing API endpoints. The application fails to properly validate and cast numeric query and queries input filters before passing them to the database querying engine. An unauthenticated attacker can exploit this vulnerability remotely to execute arbitrary SQL commands, potentially exposing administrative credentials and internal data.

Proof of Concept (PoC):

An unauthenticated remote attacker targets the public entry-listing endpoint of YesWiki. The attacker sends a GET request to `/api/bazar/entries?query=1%20UNION%20SELECT%20username,password%20FROM%20users`. The backend logic processes the unescaped queries string, treating the appended command as direct database input instructions. This results in unauthorized disclosure of sensitive system database tables, bypass of authentication, and potential data leakage.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52770>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52770>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52770>

CVE-2026-53727

Finding: SSRF and Local File Disclosure in Ruby CSS Parser

CVSS v3.1 Score: 7.5 | Severity: Unknown | Urgency Score: 68/100 | CWE: CWE-918

Score Provenance: Unverified
MITRE ATT&CK: T1190, T1018

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	None	Availability Impact	None

Description:

The Ruby CSS Parser library contains a Server-Side Request Forgery vulnerability in its file reading mechanism. The `CssParser::Parser#read_remote_file` method fails to validate input paths, letting developers fetch external or local resources blindly. An unauthenticated attacker can exploit this weakness to query internal assets or retrieve local system configuration files.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies an application leveraging Ruby CSS Parser to render user-supplied stylesheets. The attacker submits a CSS stylesheet reference with an `@import` directive pointing to `file:///etc/passwd` or an internal network IP address. The parsing engine processes the CSS document and triggers `CssParser::Parser#read_remote_file` to read the targeted local system file. This results in local file disclosure or internal server-side request forgery, revealing private infrastructure configuration details.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53727>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53727>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53727>

CVE-2026-52762

Finding: Server-Side Template Injection in YesWiki Bazar

CVSS v3.1 Score: 7.2 | Severity: Unknown | Urgency Score: 65/100 | CWE: CWE-1336

Score Provenance: Unverified
MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	High	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	High	Availability Impact	High

Description:

YesWiki contains a server-side template injection vulnerability in its Bazar Semantic Templates component. The

technical root cause is improper sandboxing of user-provided template markup processed by the rendering engine, enabling raw code execution. An authenticated administrative attacker can leverage this flaw to execute arbitrary PHP code on the server, taking over the web daemon.

Proof of Concept (PoC):

An authenticated administrator navigates to the semantic templates editor within YesWiki's Bazar extension. The attacker submits a modified template block containing malicious Twig/PHP syntax designed to execute shell commands. The backend renders the template through the vulnerable engine, resolving the code blocks as native executable scripts. This results in local system shell execution, exposing the underlying server operating system to complete compromise.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52762>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52762>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52762>

CVE-2026-53637

Finding: Order Modification Vulnerability in Sylius FormComponent

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-672

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1565, T1114

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

The Sylius Cart FormComponent contains a vulnerability that permits modification or deletion of already-completed orders. The technical root cause is improper state management and missing validation logic within the Cart FormComponent that fails to lock completed order states. An authenticated remote attacker can exploit this weakness to manipulate or delete historically completed transaction records, compromising database integrity.

Proof of Concept (PoC):

An authenticated remote attacker identifies the identifier of a historically finalized and paid order in Sylius. The attacker submits a POST request to the cart component at /cart/update-order-state with the completed order ID and modified quantities. The server-side FormComponent executes the update actions directly on the order record without verifying if the order state is already finalized. This results in unauthorized modification of financial and transactional records, severely impacting order integrity.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53637>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53637>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53637>

CVE-2026-52763

Finding: SQL Injection in YesWiki Recent Changes

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-89

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

YesWiki is vulnerable to SQL injection through the recentchanges action's period argument. The vulnerability is caused by concatenating user-supplied period parameters directly into the historical change log search query. An attacker can exploit this to achieve arbitrary database read capabilities, leading to unauthorized information disclosure.

Proof of Concept (PoC):

An authenticated remote user requests the historical changes page within YesWiki. The attacker intercepts the request and appends a UNION SQL injection string to the period parameter in /action/recentchanges. The server executes the database query directly incorporating the malicious string without escaping the special SQL syntax characters. This results in the database returning sensitive data such as internal password hashes instead of the requested modification history.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52763>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52763>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52763>

CVE-2026-53769

Finding: Upload Policy Bypass in Avo Component

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-862

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1548, T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

The Avo administration panel direct attachment upload endpoint is vulnerable to authorization bypass. This issue is due to a lack of upload authorization validation which completely bypasses the configured field-level upload policy. An authenticated user can exploit this to upload unauthorized file types or attachments, potentially compromising internal storage spaces.

Proof of Concept (PoC):

An authenticated low-privilege user accesses the Avo administrative panel dashboard interface. The user bypasses frontend fields and issues a POST request directly to the internal /avo/api/uploads endpoint with an unauthorized attachment. The backend server accepts the file payload directly without validating the user's role against the defined field attachment policies. This results in unauthorized storage utilization and permits storage of malicious binaries within

protected directory frameworks.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53769>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53769>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53769>

CVE-2026-52774

Finding: Reflected XSS in YesWiki Bazar Widget

CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 55/100 | CWE: CWE-80

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1059.007, T1204

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

YesWiki is vulnerable to reflected Cross-Site Scripting via an unescaped id parameter in the Bazar Widget HTML attributes. The vulnerability is caused by a failure to properly sanitize and contextually escape user-controlled variables before outputting them to the DOM. An unauthenticated remote attacker can exploit this by enticing a user to visit a crafted URL, resulting in arbitrary JavaScript execution in the victim's browser session.

Proof of Concept (PoC):

An unauthenticated remote attacker drafts a malicious URL targeting a YesWiki-hosted site. The URL points to /bazar/widget?id=%22%3E%3Cscript%3Ealert(document.cookie)%3C/script%3E to inject custom HTML attributes. The server reflects the id value directly into the generated widget HTML page without sanitization or HTML escaping. This results in arbitrary JavaScript execution in the context of the user's active session, allowing credential theft.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52774>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52774>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52774>

CVE-2026-52773

Finding: Reflected XSS in YesWiki Revision Handler

CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 55/100 | CWE: CWE-80

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1059.007, T1204

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

YesWiki is vulnerable to reflected Cross-Site Scripting via the unescaped time parameter in page show handler. The technical root cause is the handler/page/show.php script directly displaying the historical revision time parameter without sanitization. An attacker can exploit this weakness by sending a crafted link to an authenticated user to execute arbitrary script code within their session context.

Proof of Concept (PoC):

An unauthenticated remote attacker constructs a malicious URL targeting the historical revision module of YesWiki. The attacker sets the time parameter in the URL to a javascript URI, e.g., /handlers/page/show.php?time=%3Cscript%3Ealert(1)%3C/script%3E. The server-side script retrieves the value and injects it into the output template without invoking appropriate security filters. This results in immediate client-side code execution in the victim's browser, potentially leading to session hijacking.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52773>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52773>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52773>

CVE-2026-52772

Finding: Stored XSS in YesWiki Bazar Templates

CVSS v3.1 Score: 5.5 | Severity: Unknown | Urgency Score: 50/100 | CWE: CWE-79

Score Provenance: Unverified
MITRE ATT&CK: T1059.007, T1204

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:L/I:L/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	High	User Interaction	None
Scope	Changed	Confidentiality Impact	Low
Integrity Impact	Low	Availability Impact	None

Description:

YesWiki contains a stored Cross-Site Scripting vulnerability in its Bazar form-field templates via the raw filter. The vulnerability is caused by utilizing unescaped fields like field.label and field.hint with the raw('html') Twig filter. A authenticated attacker can exploit this to inject permanent malicious scripts into form fields, which execute when other users view those forms.

Proof of Concept (PoC):

An authenticated remote user with form creation permissions accesses the Bazar form template designer. The user configures a new field and inputs a payload containing an iframe script tag into the field.label parameter. The template engine renders the Bazar form field using the raw Twig filter, bypassing built-in HTML encoding. This results in persistent execution of the injected script whenever any administrative user or visitor views the affected Bazar form.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52772>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52772>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52772>

CVE-2026-53602

Finding: Host Revocation Bypass in Nebula Mesh

CVSS v3.1 Score: 9.1 | Severity: Unknown | Urgency Score: 49/100 | CWE: CWE-613

Score Provenance: Unverified

MITRE ATT&CK: T1116, T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The nebula-mesh network engine features an insecure host certificate revocation validation routine. The vulnerability is caused by a lack of persistence or durable validation checks for revoked certificate lists across mesh updates. A blocked or offboarded user can exploit this to regain authorization and rejoin the secure mesh network, bypassing isolation mechanisms.

Proof of Concept (PoC):

A previously offboarded mesh host retains its expired or revoked cryptographic certificate file. The host launches a connection handshake request targeting an active node in the private Nebula network. The receiving node evaluates the certificate without checking an updated durable revocation database, validating the handshake. This results in unauthorized mesh network access, bypassing designed administrative offboarding and isolation policies.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53602>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53602>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53602>

CVE-2026-53760

Finding: Cross-Site Request Forgery in Admidio Plugin Handler

CVSS v3.1 Score: 5.2 | Severity: Unknown | Urgency Score: 47/100 | CWE: CWE-352

Score Provenance: Unverified

MITRE ATT&CK: T1566, T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:R/S:U/C:N/I:H/A:L

Attack Vector	Network
Privileges Required	High
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	None
Availability Impact	Low

Description:

The Admidio plugin management module is vulnerable to Cross-Site Request Forgery on its install, uninstall, and update operations. The vulnerability is caused by using insecure HTTP GET requests for sensitive administration actions without utilizing anti-CSRF validation tokens. An unauthenticated attacker can exploit this by forcing an administrator to load a crafted URL, triggering unauthorized plugin modifications.

Proof of Concept (PoC):

An unauthenticated attacker crafts a malicious hyperlink targeting the Admidio plugin administration interface. The attacker induces an authenticated admin user to click the link, pointing to

/adm_program/modules/plugins/plugins.php?action=install&plugin=malicious_plugin. The browser submits the request under the administrator's active session, and the backend installs the plugin without token verification. This results in unauthorized plugin installation, allowing the attacker to alter site layouts or introduce secondary security backdoors.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53760>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53760>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53760>

CVE-2026-53638

Finding: Payment Method Restriction Bypass in Sylius

CVSS v3.1 Score: 4.3 | Severity: Medium | Urgency Score: 39/100 | CWE: CWE-863

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1548, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	Low	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	Low	Availability Impact	None

Description:

The Sylius shop account orders API endpoint contains a vulnerability that allows channel-based payment method restriction bypass. The issue arises from a lack of proper authorization checks on the payment method selection logic within the shop orders handler. An unauthenticated remote attacker can exploit this to bypass configured business rules, potentially leading to unauthorized payment options being used for order completion.

Proof of Concept (PoC):

An authenticated user with low privileges accesses the Sylius shop account orders API endpoint. The attacker sends a PATCH request to /api/v1/orders/123/payments with a modified paymentMethod code restricted to other channels. The server processes the request without validating whether the selected payment method is allowed for the order's specific channel. This results in complete bypass of payment restriction policies and allows the use of unauthorized payment gateways.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53638>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53638>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53638>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no

official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>